

Setnayan — Records of Processing Activities (RoPA) / Data Inventory

DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization and NPC filing; not yet adopted. · 2026-07-05

The accountability record RA 10173 (Data Privacy Act of 2012) and its IRR require a Personal Information Controller (PIC) to maintain: a register of the Data Processing Systems (DPS) it operates. Each row below is **one DPS**. Sourced from 01_Contracts/Setnayan_Privacy_and_Security_Policy.md (§1 data collected, §3 where data lives, §4 retention, §6 consent, §10 sub-processors) and 03_Strategy/Compliance_Pack_PersonGraph_DRAFT_2026-07-05.md. Facts not established in those sources are marked [TO CONFIRM] — none invented.

0. Controller & governance identification

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II
DTI Business Name Registration	BN 8297508 · valid 25 Jun 2026 – 25 Jun 2031
Brand / trade name	Setnayan
Public domains	setnayan.com · setnayan.ph
Registered business address	[TO CONFIRM]
Total headcount / employees	[TO CONFIRM]
NPC registration number (if already registered)	[TO CONFIRM]
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com (registered with the NPC per policy §9)
DPO response SLA	15 business days (non-urgent); immediate for breach notifications
Breach notification	NPC + affected users within 72 hours of confirmation (policy §8)
Estimated data-subject counts (customers / vendors / guests)	[TO CONFIRM]

Shared infrastructure (applies across DPS's unless a row narrows it)

Layer	Provider	Location	Role
Web / application hosting	Vercel	[TO CONFIRM] (edge)	Processor

Primary database (PII + transactional + biometric face vectors)	Supabase / Postgres	Singapore	Processor · AES-256 at rest · RLS. Face vectors live HERE , as JSONB columns (guest_face_enrollments.face_vectors, user_face_profiles) — corrected 2026-07-31
Media (photos / video / source selfie images)	Cloudflare R2	Asia-Pacific (APAC) ■ confirmed in the Cloudflare dashboard 2026-08-01	Processor · signed-URL access only. Does NOT hold face vectors — corrected 2026-07-31
Transactional email	Resend	[TO CONFIRM] (US-based likely)	Processor
Vendor ID verification	Persona / Veriff / Onfido	US	Processor (batch-call, no ongoing storage)
AI text/contract analysis	Anthropic (Claude) · OpenAI (V1.5 fallback)	US	Processor · zero-retention API mode (Anthropic)
Music generation	Suno	[TO CONFIRM]	Processor — no PII processed

Cross-border baseline: routine operation crosses the SG↔PH border; encrypted in transit (TLS 1.3), governed by Cloudflare's and Supabase's PH-compliant DPAs, subject to NPC oversight (policy §10). US sub-processors are bound by Standard Contractual Clauses (SCCs) or equivalent (policy §10).

1. Records of Processing Activities — one record per Data Processing System

Legend — Legal basis per RA 10173 §12 (personal info) / §13 (sensitive personal info): **Contract** = §12(b) performance of contract; **Consent** = §12(a)/§13(a); **Legitimate interest** = §12(f); **Legal obligation** = §12(c)/§13(b)/§13(f). SPI = Sensitive Personal Information per RA 10173 §3(l).

DPS-01 · Customer / Couple Account & Event Planning

Field	Detail
Purpose	Provide the contracted planning platform: account, event setup, vendor matching (Guided + DIY), seating, save-the-date, in-app services
Legal basis	Contract (§12(b)) — service delivery; Consent (§12(a)) for marketing-sample opt-in (policy §6.2)
Data subjects	Customers (couples / organizers)
Personal data categories	Full name, mobile, email, optional profile photo; event data (date, venue, target pax, role); behavioral/in-app activity, Guided-mode decisions, search queries; uploaded content (Save-the-Date photos, invitation customizations)
SPI?	N (no SPI in the core account record)
Recipients / sub-processors	Supabase (DB), Vercel (hosting), Cloudflare R2 (content); Setnayan Team on mediation only

Cross-border transfer	SG (Supabase); APAC (R2)
Retention	Account profile: active + 30-day grace on deletion, then purge. Event data: Kept for the LIFE OF THE ACCOUNT, deleted when the couple closes or deletes their account (plus the existing 30-day tail). Owner ruling 2026-08-17. ■ CORRECTED — the previous "5 years post-event, auto-purge at T+5y" rule is WITHDRAWN, not merely unbuilt. Building it as written would have DELETED THE PHOTOS: in the live schema the photo rows, the guest list, the tags, the schedule and the supplier list all cascade from the event, so removing a wedding removes its album — contradicting the owner's twice-locked rule that no photo is ever deleted, only compressed. Retention is therefore bound to the purpose that is still running (the couple's own album and its context) rather than to a timer, matching the treatment of account data. Any future end date must be built to remove planning details WITHOUT touching the photos.
Security measures	AES-256 at rest; RLS per-user isolation; TLS 1.3; bcrypt passwords; optional 2FA; signed URLs for media
Risk level	Medium

DPS-02 · Vendor Account, Profile & Verification

Field	Detail
Purpose	Vendor onboarding, business profile, and the 12-document identity/business verification checklist (policy §3.4)
Legal basis	Contract (§12(b)); Legitimate interest (§12(f)) — DTI lookup, portfolio reverse-image, reference calls; Legal obligation (§13(f) / §12(c)) — AMLC sanctions/PEP screening per PH AMLA; Consent captured at registration
Data subjects	Vendors (business owners / primary representatives)
Personal data categories	Business identity (DTI Business Name Cert, BIR Form 2303, Mayor's Permit, business address, name+slug); service profile; financial (bank/e-wallet payout account, transaction history); behavioral (response times, conversion)
SPI?	Y — government-issued ID of the primary representative (RA 10173 §3(l) SPI); selfie + ID liveness video (biometric-adjacent). DTI/BIR/tax documents are legally-mandated records
Recipients / sub-processors	Persona / Veriff / Onfido (ID + liveness); AMLC API / ComplyAdvantage (sanctions/PEP); DTI Database (BN validation); Supabase; Cloudflare R2 bucket setnayan-vendor-verification (Verification Handler role only)
Cross-border transfer	US (Persona/Veriff/Onfido); UK (ComplyAdvantage); PH (AMLC, DTI); SG (Supabase); APAC (R2)

Retention	Raw uploads (government ID, selfie + liveness video, bank micro-deposit, portfolio): deleted 90 DAYS AFTER the approve/reject decision — owner ruling 2026-08-17, which makes true the promise this row already made. The DECISION RECORD ONLY (outcome, deciding admin, timestamp, screening result) is retained 7 years (BIR §235 + AMLC AML/CTF). DTI / BIR 2303 / Mayor's Permit: 7 years. Transaction history: 5 years (policy §4). ■ ADOPTED 2026-08-17, ENFORCEMENT NOT YET BUILT. No sweep implements this period yet — today the only thing that removes this data is an erasure/revocation request. The period stated is the ADOPTED RULE, not a description of current behaviour. ■ CORRECTED 2026-08-17 (same day): an earlier revision of this row said <i>"production has ZERO scheduled jobs, so no automatic deletion of any kind runs today"</i> — that was wrong. Setnayan deliberately runs cron-free: a database compare-and-swap claim fired from request traffic drives ~16 periodic jobs, all verified running on 2026-08-17, and several DO delete automatically (a 5-year chat purge, a 180-day Deep-Search-dossier purge, an anonymous-draft sweep, and the full-resolution photo replacement). The gap is that no job covers THIS class yet — not that the machinery is absent. Stating the period alone would replace a false promise with a newer one.
Security measures	Extra-restricted R2 bucket (single admin role); batch-call verification (no ongoing sub-processor storage); AES-256; RLS; audit log on all admin decisions
Risk level	High (SPI: gov ID + biometric liveness)

DPS-03 · Guest List & RSVP

Field	Detail
Purpose	Manage the couple's guest list, RSVP status, roles, table assignment, and special requests
Legal basis	Contract (§12(b)) — organizer's event service; Consent (§12(a)) for guest-provided data / photo consent at RSVP (policy §6.1)
Data subjects	Guests
Personal data categories	Full name, mobile, email, optional profile photo; event linkage + role (principal/secondary sponsor, family, friend), RSVP status, table assignment; behavioral (reels built, re-shares)
SPI?	Potentially Y — dietary restrictions / special-needs data collected at RSVP may reveal health or religious SPI (RA 10173 §3(l)). [TO CONFIRM] exact special-data fields captured in the RSVP schema
Recipients / sub-processors	Supabase; event organizer (couple); coordinator within join-permission scope
Cross-border transfer	SG (Supabase)

Retention	Aligned with event retention: 5 years post-event; deletion cascades on guest account deletion (subject to shared-gallery organizer-consent exception, policy §4)
Security measures	RLS event-scoping; TLS 1.3; guest opt-out toggles; AES-256
Risk level	Medium (High if dietary/health SPI confirmed)

DPS-04 · Face Vectors / Auto-Tagging (per-event, consented)

Field	Detail
Purpose	Auto-tag guests in an event's photo gallery via face matching (couple-scoped only)
Legal basis	Consent (§13(a)) — guest opts in by uploading RSVP profile photo for this purpose; revocable via "Delete my face data" / Photo Consent toggle (policy §6.1)
Data subjects	Guests
Personal data categories	128-dimension face vectors derived from RSVP photo + optional portal upload + on-the-day check-in kiosk
SPI?	Y — BIOMETRIC data (RA 10173 §3(l)). Highest-sensitivity category in the platform
Recipients / sub-processors	Supabase (Singapore) — the vectors themselves , as JSONB in <code>guest_face_enrollments.face_vector</code> + <code>user_face_profiles</code> ; Cloudflare R2 (APAC) holds only the source selfie image (<code>asset_url</code>). ■ [TO CONFIRM] RESOLVED 2026-07-31 from shipped code: there is NO third-party matching engine. Embedding runs on-device / in-browser (<code>face-api.js</code> / <code>MediaPipe</code> , <code>lib/face-embed.ts</code>) and matching runs against our own Postgres rows — no face data is sent to any AI sub-processor. (Prior text placed a "per-event encrypted vector index" on R2; no such index was ever built.)
Cross-border transfer	Singapore (Supabase — the vectors) + APAC (R2 — the source selfie images). Corrected 2026-07-31; both outside PH, so the § cross-border conclusion is unchanged, but the <i>location of the biometric SPI</i> is now stated accurately.

Retention	Deleted 3 MONTHS AFTER THE EVENT ENDS (event_end_date where the celebration spans several days, else event_date) — the same clock as the full-resolution photo floor. Owner ruling 2026-08-17. Earlier deletion any time via the guest's "Delete my face data" link or Photo Consent OFF (≤ 5-minute revocation), which DO work today. ■ ADOPTED 2026-08-17, ENFORCEMENT NOT YET BUILT. No sweep implements this period yet — today the only thing that removes this data is an erasure/revocation request. The period stated is the ADOPTED RULE, not a description of current behaviour. ■ CORRECTED 2026-08-17 (same day): an earlier revision of this row said "production has ZERO scheduled jobs, so no automatic deletion of any kind runs today" — that was wrong. Setnayan deliberately runs cron-free: a database compare-and-swap claim fired from request traffic drives ~16 periodic jobs, all verified running on 2026-08-17, and several DO delete automatically (a 5-year chat purge, a 180-day Deep-Search-dossier purge, an anonymous-draft sweep, and the full-resolution photo replacement). The gap is that no job covers THIS class yet — not that the machinery is absent. Stating the period alone would replace a false promise with a newer one. ■ Deleting face data does NOT remove photo tags — verified in the live schema: a tag carries the guest link itself and has no reference to face data, so nothing cascades. Guests keep every photo already delivered; only FUTURE automatic matching is lost, which is why the 3-month mark is safe. ■ CORRECTED 2026-08-17 — this row previously declared a "per-event lifetime + 5 years, auto-purge with event data" rule, which nothing implemented — and which had silently become "never deleted" when the media row moved to indefinite retention on 2026-08-02.
Security measures	Per-event scoped — vectors never reused across events; encrypted at rest; no cross-event face recognition (design lock, Person Graph DPIA #6); confidence-gated auto-tag
Risk level	High (biometric SPI)

DPS-05 · Papic / Photo & Video Capture & Delivery

Field	Detail
Purpose	Capture, store, tag, and deliver event photos/clips to couples and guests; Personal Reel rendering
Legal basis	Contract (§12(b)) — paid capture/delivery service; Consent (§6.1) for likeness/photo participation; opt-out → face-blur
Data subjects	Guests, customers (couples); incidental non-account attendees appearing in media

Capture sources <i>(added 2026-08-02 — closes DPO gate 0d)</i>	Three, and the RoPA previously named none of them explicitly: (1) designated paparazzi seats (a friend/family member claims a seat and shoots); (2) the guests' OWN PHONES — a guest buying or being granted Papic captures on their personal device, which is the dominant source now that Papic Pool sells as a shared-shot pool; (3) a paired DSLR bridged through a paired phone. Source (2) is the one this amendment exists to state: the media in this system is largely captured by ordinary attendees on their own handsets, not by an operator Setnayan or the couple controls
Personal data categories	Photos and video clips; likeness; capture metadata (<code>captured_at</code> , geo when available, device model, paired camera brand/model); tag associations
Delivery mechanism <i>(added 2026-08-02 — closes DPO gate 0d)</i>	Media is sorted to a guest by face matching where that guest consented to it (DPS-04), and delivered to their personal gallery. So a guest's likeness, captured on a <i>stranger's</i> phone, reaches them through an automated biometric match. The untagged-still-delivered rule means the couple receives everything regardless
SPI?	N in the general case (images of persons are personal info, not per-se SPI), but images can incidentally reveal SPI (health, religion). Treat as elevated
Recipients / sub-processors	Cloudflare R2 (originals, signed-URL only); Supabase (tags/metadata); hierarchical read: organizer / coordinator / guest (tagged + global) / vendor (booking-relevant)
Cross-border transfer	APAC (R2)
Retention	Full-resolution ORIGINAL: the later of 6 months from the event's first capture and 3 months after the event ENDS (the celebration's last day: <code>event_end_date</code> where the event spans several days, else <code>event_date</code> — owner 2026-08-10), then replaced by a compressed web copy. Compressed web copy: free for 5 years; past 5 years, continuing to store it becomes a paid option whose price is not yet set (owner 2026-08-07, superseding the 2026-07-10 "free forever" lock). ■ Nothing is deleted at 5 years — the owner set a price REVIEW, not a deletion, and the consequence of declining to pay is NOT decided. Do not build or document a 5-year purge. No scheduled deletion at any point. No photo is ever deleted on a schedule. Disposal occurs only on organizer removal, a validated erasure request, or account deletion. Originals synced to the couple's own Google Drive are theirs permanently and are never touched. Geo stripped on outbound shares; the original on R2 retains it (policy §4). ■ CORRECTED 2026-08-07. This row previously declared a 5-year hard limit with 90-day-hot/5-year-cold tiering. That tiering was never built, no R2 lifecycle rule exists, and the compressed copy is kept indefinitely — so the row committed us, in a filing, to destroying photos we in fact keep. Declaring a purge that never happens is the more dangerous direction of drift: a commitment to the regulator broken every day.

Security measures	Signed URLs (5-min for sensitive media); no public reads; NSFW filter on-by-default (non-disableable); untagged-still-delivered; opt-out face-blur; couple review window before public unlock
Risk level	Medium–High

DPS-06 · Person Graph — Connections, Life Stories & Trusted-Circle (adults-only)

Field	Detail
Purpose	Durable person node; mutually-confirmed relationship connections; per-person life-story references; aggregate trusted-circle vendor signal (Person Graph pack)
Legal basis	Consent (§12(a)) — mutual, opt-in confirmation required for every edge; life stories rely on existing RSVP photo consent
Data subjects	Customers, guests (adults only — minors NOT processed)
Personal data categories	Person node (name, optional photo, events participated); first-degree connection edges (type + confirmed/pending state); life-story items = references (pointers), not copies ; trusted-circle signal = computed on read, not stored
SPI?	Potentially Y — relationship data can infer SPI (e.g., civil status, family/religious ties). Mitigated: extended kin derived not stored ; min-N ≥5 on aggregates
Recipients / sub-processors	Supabase (edges + references); no third-party sharing; connections never broadcast/browsable
Cross-border transfer	SG (Supabase)
Retention	Edges + references follow event/account retention (policy §4 / Compliance Pack §3); declined/hidden/opted-out suppressed immediately; reference dies with source media; trusted-circle not stored
Security measures	Mutual-confirmation gate; name-only + confirmed-only cross-person visibility; participant-scoped deny-by-default RLS; no "people you may know"; no cross-event face recognition ; DPIA completed (Compliance Pack §2, residual Low)
Risk level	Medium — Status: DRAFT, live behind flags; pending DPO/counsel sign-off. Minors/legacy (Phase 3) counsel-first, DPIA scoped-not-complete, not processed

DPS-07 · In-App Communications / Chat (0019)

Field	Detail
Purpose	Text chat between couples ↔ vendors ↔ coordinators; document/sheet/PDF/image sharing on threads
Legal basis	Contract (§12(b)) — coordination is core service

Data subjects	Customers, vendors, coordinators
Personal data categories	Chat message content; attached files (doc/sheet/PDF/image); pasted external meeting links (plain text). Vendor identity masked (company logo, not personal photo)
SPI?	N structurally, but free-text/attachments may contain SPI — treat as elevated
Recipients / sub-processors	Supabase Realtime (ephemeral) + Postgres (history); Cloudflare R2 thread-files bucket. Video meetings RETIRED 2026-05-16 — no video data stored
Cross-border transfer	SG (Supabase); APAC (R2)
Retention	Messages: 5 years (aligned to event retention). Pasted meeting links follow parent message (policy §3.3, §4)
Security measures	RLS thread-scoping; per-thread coordinator join permission; vendor-identity masking; TLS 1.3; AES-256
Risk level	Medium

DPS-08 · Payments & Reconciliation (apply-then-pay)

Field	Detail
Purpose	Process PHP-direct service orders: BDO/GCash apply-then-pay, reference codes, manual reconciliation of proof-of-payment against orders
Legal basis	Contract (§12(b)); Legal obligation (§12(c)) — PH tax/BIR record retention
Data subjects	Customers, vendors
Personal data categories	Payment receipts, transaction references, partial bank/e-wallet details for receipts/refunds; payment-proof screenshots; reconciliation inbox messages. No complete card numbers, CVVs, or full bank account numbers stored
SPI?	N
Recipients / sub-processors	Supabase (payments, service_orders, payment_inbox_messages); Setnayan Team (manual reconciliation); Maya Business (V1.5+ gateway [TO CONFIRM] not active)
Cross-border transfer	SG (Supabase)
Retention	Transaction/receipt records: 5 years (tax compliance). Pending orders expire 7 days (policy §4, CLAUDE.md)
Security measures	No card/full-account storage; two-admin approval for refunds >₱10K; append-only audit log; RLS; reference codes 8-char Crockford
Risk level	Medium

DPS-09 · In-App Behavioral / Product Analytics

Field	Detail
Purpose	Platform analytics for Setnayan admins (aggregated); platform improvement + ML model training (anonymized)
Legal basis	Legitimate interest (§12(f)) for aggregated operational analytics; Consent (§12(a)) for the secondary anonymized-training purpose (policy §2.1, §2.2)
Data subjects	Customers, vendors, guests
Personal data categories	In-app activity, surfaces visited, services purchased, vendor interactions, search queries, response/conversion metrics. Aggregated — never individually identified to admins outside dispute-mediation context
SPI?	N
Recipients / sub-processors	Supabase; PostHog [TO CONFIRM] (referenced in repo/iteration 0035; not named in this policy) — no PII per observability design
Cross-border transfer	SG (Supabase); PostHog host [TO CONFIRM]
Retention	Anonymized aggregate: indefinite (no PII). Underlying behavioral rows follow account/event retention (policy §4)
Security measures	Aggregation + de-identification for admin views; no PII in logs; opt-out toggle (per observability design) [TO CONFIRM]
Risk level	Low–Medium

DPS-10 · Email Notifications (Resend)

Field	Detail
Purpose	Transactional + milestone email: payment instructions/confirmation, refunds, vendor messages/status, RSVP received, wedding-day reminder, save-the-date, security alerts
Legal basis	Contract (§12(b)) for transactional mail; Consent (§12(a)) for promotional/marketing mail (revocable; RFC 8058 one-click unsubscribe)
Data subjects	Customers, vendors, guests
Personal data categories	Email address, recipient name, event/order context embedded in the message
SPI?	N
Recipients / sub-processors	Resend (delivery); SendGrid fallback [TO CONFIRM]
Cross-border transfer	US-based email provider likely [TO CONFIRM] (Resend jurisdiction)

Retention	Follows the underlying record; delivery logs [TO CONFIRM] retention at provider
Security measures	TLS in transit; one-click unsubscribe; RA 10173 + CAN-SPAM compliant templates
Risk level	Low

DPS-11 · Marketing Site / Cookies & Consent

Field	Detail
Purpose	Public marketing site (setnayan.com); analytics/consent management on public surfaces
Legal basis	Legitimate interest (§12(f)) for essential/first-party operation; Consent (§12(a)) for analytics/advertising cookies
Data subjects	Website visitors (prospective customers/vendors), guests
Personal data categories	Cookie/consent state, IP, user-agent (policy acceptance is logged with timestamp + IP + user-agent), first-party analytics identifiers
SPI?	N
Recipients / sub-processors	Vercel (hosting); analytics processor [TO CONFIRM]. Note: third-party display ads (AdSense) were RETIRED 2026-05-19 — no third-party ad cookies
Cross-border transfer	[TO CONFIRM] (edge/analytics host)
Retention	Consent state persistence [TO CONFIRM] (design referenced 12-month persistence); policy-acceptance log per user retained with account
Security measures	First-party cookie model; consent categories (essential / analytics / advertising); TLS 1.3; HSTS; CSP
Risk level	Low

DPS-12 · Anti-Fraud & Trust Integrity (identity clustering · fraud scoring · enforcement)

Field	Detail
Purpose	Protect marketplace trust signals from manipulation: cluster likely-same-person/household accounts by shared strong signals; de-duplicate vendor review/rating/booking stats per cluster with arm's-length exclusion; score per-vendor fraud anomalies; two-stage enforcement (reversible auto-suspend + human four-eyes wipe/ban). Spec 03_Strategy/Anti_Fraud_Trust_Integrity_2026-07-05.md

Legal basis	Legitimate interest (§12(f)) — fraud prevention / marketplace integrity. Requires a documented legitimate-interest balancing + disclosure (both outstanding — DPIA R-08 §6). Automated-suspension effect engages §16(c) (right to object) + §34 (automated processing) [TO CONFIRM] counsel
Data subjects	Couples / guests (whose device/address/payment signals are clustered — they never see cluster membership) + vendors (scored, and subject to auto-suspend / ban)
Personal data categories	Repurposed inputs (no new collection) : device fingerprint (<code>user_devices.device_hash</code>), normalized home address (<code>users.address_normalized</code>), payment-sender identity (<code>payments.reference_number</code> →paying user). Derived : identity <code>cluster_id</code> ; per-vendor fraud signals + 0–100 scores with non-PII evidence (counts/ratios/opaque labels); enforcement state + append-only audit. IP deliberately NOT captured
SPI?	N — inputs are personal information, not §3(l) SPI. Elevated because it is involuntary profiling with an automated decision that has a significant effect (vendor livelihood)
Recipients / sub-processors	Supabase (Postgres, Singapore) only — no third-party/AI sub-processor. Service-role / admin ONLY (REVOKE ALL FROM anon, authenticated + <code>is_admin()</code> RLS at CREATE); Setnayan admins via <code>/admin/fraud</code> + two-admin approval gate
Cross-border transfer	SG (Supabase)
Retention	<code>identity_clusters</code> / <code>vendor_fraud_scores</code> = recomputed matviews (no history). <code>fraud_signals</code> + <code>fraud_enforcement_audit</code> persist — explicit retention rule not yet defined [TO CONFIRM] . Signal inputs follow their source systems (device/address = account retention; payment = 5-yr tax, DPS-08)
Security measures	Service-role/admin-only + deny-by-default RLS at CREATE; non-PII evidence; reversible auto-suspend at high threshold (score ≥90); irreversible ban never automated — four-eyes gate + typed confirmation; append-only audit; help-center appeal path; AES-256; TLS 1.3
Risk level	High — Status: LIVE in production since 2026-07-07, ahead of counsel sign-off (owner-elected) . DPIA R-08 drafted (<code>08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md</code>); Privacy Policy Anti-Fraud disclosure + LIA + formal contest path outstanding

DPS-13 · Vendor AI Assistant — automated replies + business deep-search (0022)

Field	Detail
-------	--------

Purpose	The paid Vendor AI add-on, two capabilities: (a) Auto-reply — reads a couple's inbound messages + Event Brief (event date, guest count, budget-per-head, venue) in that couple↔vendor thread and drafts/auto-sends replies (and, if the vendor allows, accepts a booking) on the vendor's behalf, shown to the couple labelled "■ AI auto-reply"; (b) Deep Search — runs AI web-research over the vendor's own business across public sources (own website, directories, review sites) and stores a structured business dossier (vendor_web_dossiers) the vendor reviews to auto-fill its profile. Both are gated behind the <code>/admin/data-privacy</code> controls <code>vendor_ai_autoreply</code> + <code>vendor_deep_search</code> (fail-closed until DPO-activated)
Legal basis	Contract (§12(b)) — the vendor's paid add-on operating on the vendor's own shop; Consent (§12(a)) — the couple's own act of messaging that vendor grounds the auto-reply reading their thread. Auto-reply is automated processing (§34) with a standing "■ AI auto-reply" label and a §16(c) object path (every message still reaches the vendor). Deep Search of already-public third-party content relies on legitimate interest (§12(f)) , minimised to a business summary with a 180-day retention limit <code>[TO CONFIRM]</code> counsel
Data subjects	Couples (inbound message text + Event Brief the auto-reply reads) + vendors (own business researched, dossier stored) + incidental third parties named on public web pages (Deep Search, e.g. a reviewer's public name)
Personal data categories	Auto-reply: couple inbound chat text + structured Event Brief fields (date, pax, budget band, venue) + the vendor's own package/pricing config; generated reply text. Deep Search: the vendor's own public business info (name, contact, services, review-derived facts) → vendor_web_dossiers . Never consumes SPI, face vectors, religion/faith, or the guest list
SPI?	N — no SPI; biometric, faith, and guest-PII consumption are explicitly carved out
Recipients / sub-processors	Supabase (Postgres, Singapore); Anthropic web_search (US, Deep Search only) — zero-retention API mode. Single-tenant isolation: a vendor's assistant reads only that vendor's own threads/business, never across vendors or across the couple's events
Cross-border transfer	SG (Supabase); US (Anthropic — Deep Search only)
Retention	Deep Search dossier vendor_web_dossiers — rolling 180-day TTL <code>[TO CONFIRM]</code> . Auto-reply reads live thread + Event Brief data in place (no separate store beyond the chat system, DPS-07)
Security measures	Per-vendor single-tenant isolation; both capabilities fail-closed until DPO-activated on the <code>/admin/data-privacy</code> control board; "■ AI auto-reply" transparency label; SPI / face / guest-list carve-out enforced in code; TLS 1.3; AES-256

Risk level	Medium — automated processing (§34) of couple message content + AI web-research that may store incidental third-party PII. Public Privacy Policy §"Vendor AI assistant" + §"Vendor Deep Search" disclosures LIVE ; the <u>/admin/data-privacy</u> controls hold both OFF until DPO sign-off; retention rule + LIA finalization outstanding
-------------------	--

DPS-14 · Coordinator Delegated Access — consent scopes + prep-then-release (0021)

Field	Detail
Purpose	Let a couple delegate planning access to a coordinator they invite (a planner / family / friend — host-side, not Setnayan staff). At invite the coordinator accepts an RA 10173 consent modal scoping access to the couple's guest list, seating, schedule, and vendor chats . The couple may optionally grant "Can finalize vendors" and "Can handle payments" scopes (lock vendors + complete an apply-then-pay checkout on the couple's behalf). Prep-then-release lets the coordinator stage run-of-show/schedule blocks privately and release them to the couple (staged blocks hidden from couple/guests/vendors until released). Gated behind the <u>/admin/data-privacy</u> controls <u>coordinator_consent_money</u> + <u>coordinator_prep_release</u> (fail-closed)
Legal basis	Consent (§12(a)) captured on the invite modal + Contract (§12(b)) — service delivery. Money scopes are opt-in by the couple ; consistent with the platform-wide rule that Setnayan never HOLDS and never MOVES money — settlement is direct couple↔vendor, off-platform, and the coordinator merely prepares the same off-platform payment. ■ CORRECTED 2026-08-17 — the word "records" was struck: it was FALSE . Setnayan DOES record couple→supplier payments the couple enters in their own budget — amount, date, method and reference number, with the supplier able to confirm receipt in-app. Measured in production 2026-08-17: 3 payment records totalling ■111,500 (2026-05-28 → 2026-06-05). Those records are declared at DPS-20 below. The 0%-commission position is untouched: we never touch the money, we only write down that the couple says they paid it.
Data subjects	Couples (planning data + optional money authority delegated) + guests (whose PII the coordinator sees within scope) + coordinators
Personal data categories	Guest list + RSVP data, seating, schedule / run-of-show, vendor chat threads — scoped to the granted permissions; optional money-adjacent actions (vendor finalize, checkout) when the couple grants the scope; staged prep-release schedule blocks (hidden until released). Face / biometric data excluded
SPI?	N — no new SPI collection; scoped delegated access to the couple's existing planning data (incl. guest PII)
Recipients / sub-processors	Supabase (Postgres, Singapore) — RLS event/thread scoping + per-thread coordinator join permission (see DPS-07). No new sub-processor

Cross-border transfer	SG (Supabase)
Retention	Follows the parent event data (DPS-01 / DPS-03 / DPS-07) — 5 years post-event. Coordinator access is revocable by the couple at any time; revocation removes access prospectively
Security measures	RLS event/thread scoping; consent captured at invite (durable proof); money scopes opt-in and separately gated; face/biometric excluded; staged prep-release hidden until released; controls fail-closed until DPO-activated; TLS 1.3; AES-256
Risk level	Medium — widens a coordinator's access over guest PII and, if the couple grants it, money-adjacent actions. Public Privacy Policy §"Coordinators you invite" disclosure LIVE ; confirm the DPO ruling before activating the <code>coordinator_consent_money</code> control

DPS-15 · Guest-Written Columns — guest-authored text published to the open web (2026-08-02)

Field	Detail
Purpose	Let a guest write one short column (title + body) for the couple's event page. After the couple approves it, the column is published on the open web on the public event page and may carry into the post-event editorial, under a byline drawn from the guest-list name
Legal basis	Consent (§12(a)) — captured at submit time and stored as a durable timestamp (<code>consent_captured_at</code> , NOT NULL backstop); publication additionally requires the couple's approval. Withdrawal is self-serve and immediate
Data subjects	Guests (authors); persons named inside a guest's free text (incidental)
Personal data categories	Guest-authored free text (title ≤60 chars, body ≤280 chars) + the author's byline (their name as it appears on the event's guest list). No contact details are published
SPI?	N by design, but elevated — free text is unbounded in content and a guest may volunteer health, religious or political statements about themselves or others. Tier-1 automatic screening runs on every submit; treat as elevated
Recipients / sub-processors	The open web (public event page; post-event editorial). Supabase (Postgres, SG) for storage. No new sub-processor
Cross-border transfer	SG (Supabase); the published page is world-readable by nature
Retention	Lives with the guest record and the event. Withdrawal by the author removes it from the page immediately ; deleting the guest record or the event removes it with them

Security measures	Two independent gates before any publication (automatic screening and couple approval — nothing auto-publishes); consent timestamp captured at submit so consent is never assumed; self-serve takedown (RA 10173 right to erasure/blocking); capability held fail-closed by the <code>/admin/data-privacy</code> control <code>guest_columns</code>
Risk level	Medium — publication of a named individual's words to the open web. Public Privacy Policy §"Guest-written columns on an event page" disclosure LIVE (scope, approval gate, byline, withdrawal, consent capture all stated)

DPS-16 · Papic Shared Pool — event-wide guest media visibility + self-linking (2026-08-02)

Field	Detail
Purpose	When the host opens the shared pool for their event, let every signed-in guest of that same event browse the event's whole capture pool, and let a guest self-link to a photo they appear in ("I'm in this"), which joins that photo to their personal gallery, ZIP download and Story reel
Legal basis	Contract (§12(b)) — the capture/delivery service the couple bought; Consent (§12(a)) — the guest's capture-time opt-in and the per-photo consent state; the host's per-event toggle (<code>events.pool_gallery_open</code> , default FALSE) is the additional gate
Data subjects	Guests whose likeness appears in the media; guests as viewers; incidental non-account attendees appearing in media
Personal data categories	Compressed web copies only of photos and short clips (never the geo-bearing original); <code>manual_pick</code> photo tags created by a guest self-linking
SPI?	N in the general case (images of persons are personal info, not per-se SPI), but images can incidentally reveal SPI. Treat as elevated — see DPS-05
Recipients / sub-processors	Other signed-in guests of the SAME event only — never the public, never anyone outside that event, never across events. Cloudflare R2 (web copies, signed-URL), Supabase (tags). No new sub-processor
Cross-border transfer	APAC (R2) + SG (Supabase) — unchanged from DPS-05

Retention	Follows DPS-05 — full-resolution ORIGINAL held the later of 6 months from the event's first capture and 3 months after the event ENDS, then replaced by a compressed web copy; the compressed copy is free for 5 years and thereafter a paid option whose price is not set. ■ No photo is ever deleted on a schedule — only its resolution changes. The host's toggle closes the pool retroactively — turning it off withdraws event-wide visibility from media already captured. ■ CORRECTED 2026-08-17. This row was drafted 2026-08-02 and back-referenced DPS-05 as "90 days hot + 5 years IA cold" — the tiering that DPS-05 itself had already retired on 2026-08-07. It was never built, no R2 lifecycle rule exists, and it declared a destruction we do not perform.
Security measures	The pool read is a single RPC that bakes in all three protections: the FaceBlock blur rule, the photo_consent veto, and web-copy-only keys so a geo-bearing original can never be served here; automatic screening must have passed; scoping is per-event and cannot drift; capability held fail-closed by the /admin/data-privacy control papic_pool_gallery
Risk level	Medium-High — this is the widening from <i>per-guest tagged delivery</i> to <i>event-wide visibility</i> : a guest's shots become visible to every other guest at that celebration. Public Privacy Policy §"Photos and videos — location data and guest capture" discloses the shared pool explicitly (scope, web-copies-only, screening, event-scoping, self-linking, and how to avoid it) — LIVE

DPS-17 · Same-Date Demand Signal — cross-couple aggregate (2026-08-02)

Field	Detail
Purpose	Tell a couple how many other couples have inquired with the same vendor for the same exact date , and feed that number to the "In demand right now" ranking lens as a sub-score
Legal basis	Legitimate interest (§12(f)) — marketplace transparency so a couple can judge urgency on real activity rather than on a scarcity claim. Balancing test rests on the three minimisations below
Data subjects	Customers (couples) — both the couple who sees the number and the couples counted in it
Personal data categories	An aggregate count only. No identity, no event id, no vendor-couple pairing and no date of any other couple leaves the server — the recipient receives an integer
SPI?	N
Recipients / sub-processors	The inquiring couple, in-app only. No new sub-processor ; the aggregation is a Postgres read
Cross-border transfer	SG (Supabase)
Retention	None — the count is computed per request and never stored

Security measures	Three minimisations, all server-side: (1) inquiry-only — the count discriminates on <code>chat_threads</code> existence, so a vendor a couple merely <i>saved</i> contributes zero (a save is not competition — owner ruling 2026-06-02); (2) min-3 floor — nothing below <code>MIN_DEMAND_COUPLE_COUNT = 3</code> is returned at all, because $n=1$ on a solo vendor for an exact date in a small municipality is functionally re-identifying; (3) exact-date only , with no month/year fallback, so a couple without a fixed date generates and receives nothing. Capability held fail-closed by the <code>/admin/data-privacy</code> control <code>same_date_demand</code> (seeded inactive)
Residual concern for the DPO	There is no per-couple opt-out. A couple cannot exclude their own inquiry from the counts other couples see. The mitigation is that what is disclosed is an aggregate at or above 3, never an identity — but the absence of an opt-out is the point on which a ruling is asked
Risk level	Low–Medium — the only cross-couple disclosure on the marketplace, but bounded to an integer ≥ 3 . Public Privacy Policy §"Vendor interest counts (what other couples can see)" disclosure LIVE

DPS-18 · Live Video Connections — WebRTC signalling + TURN relay (2026-08-02)

Field	Detail
Purpose	Carry live audio/video directly between two devices for: voice/video calls inside a vendor conversation; a camera operator's phone feeding the couple's Live Studio control room; a guest tapping a side camera on an event page; and the homepage live demo. Relay the media through a TURN server only when a direct path is impossible
Legal basis	Contract (§12(b)) — delivery of the calling / Live Studio features the user initiated
Data subjects	Couples, vendors, coordinators, guests, camera operators — anyone who joins a live connection
Personal data categories	IP addresses , as ICE candidates. A direct connection is only possible if each device learns the other's address; this is inherent to WebRTC everywhere, not something Setnayan adds. Plus a per-connection technical record of whether the path was direct or relayed and the general network type
SPI?	N
Recipients / sub-processors	The other participant's device (inherently receives the IP). STUN address discovery: Google or Cloudflare public servers. TURN relay (relayed sessions only). Setnayan's own infrastructure carries the setup messages in transit
Cross-border transfer	Yes — STUN/TURN endpoints are outside PH

Retention	Addresses are not retained. The candidate addresses pass through the signalling path in transit and are not written to the database, not logged, and not used for anything else . What is kept per connection is direct-vs-relayed + general network path type, for sizing relay cost — that record contains no IP address and no audio or video
Security measures	Calls are never recorded (platform lock). Media is end-to-end between the two devices on a direct path; on a relayed path the TURN server forwards encrypted media it cannot read. No content of any call is stored
Risk level	Medium — IP exposure between participants is unavoidable for the feature to exist and is disclosed in plain language rather than buried. Public Privacy Policy §"Live video connections (calls and event cameras)" explains the IP exchange, the STUN contact, the in-transit-only signalling, and exactly what is kept — LIVE . <i>(This entry closes the RoPA item owed for WebRTC/TURN — security handoff task #42.)</i>

DPS-19 · Coordinator Day-of Operations — filtered run-of-show · announcements · requests desk (2026-08-02)

Field	Detail
Purpose	The three surfaces a coordinator acts from on the event day, as distinct from the planning-phase delegation in DPS-14: (1) the filtered run-of-show — one master timeline auto-filtered per audience; (2) day-of announcements — a short broadcast to the event; (3) the requests desk — a single inbox of things raised on the floor
Why a separate entry	DPS-14 declares the coordinator's <i>consent scopes</i> and <i>prep-then-release</i> , i.e. what a coordinator may see and stage. It never named these three, and all three are active in production . Two of them are outward actions rather than reads — one of which reaches the couple's guests — so they belong on the register in their own right
Legal basis	Contract (§12(b)) — running the event the couple engaged the platform for; Consent (§12(a)) — the coordinator's own access consent captured at invite (DPS-14)
Data subjects	Couples; guests (as announcement recipients and as the subject of floor requests); vendors (as filtered-timeline recipients and requesters); coordinators
Personal data categories	Run-of-show : schedule blocks + responsible-party tags. Announcements : free text ≤500 chars + the sender's identity and timestamp; immutable once posted. Requests desk : the request's free text + who raised it + its lane/status
SPI?	N — no new sensitive category. Free text in an announcement or a request is unbounded in principle; both are event-scoped and short-lived

Recipients / sub-processors	Announcements are read by everyone on the event — couple, guests and vendors alike (RLS Pattern B member read + delegate read + admin observability). Run-of-show is <i>narrowed</i> per audience: a vendor sees only blocks they are tagged responsible on, a guest sees only public rows, the couple sees the master. Requests stay between the raiser and the coordinator/couple. Supabase (Postgres, SG). No new sub-processor
Cross-border transfer	SG (Supabase)
Retention	Follows the parent event — deleted with it (ON DELETE CASCADE). ■ Corrected 2026-08-17: this read "inside the 5-year event-data window"; that window is WITHDRAWN — event data is now kept for the life of the account (see DPS-01)
Security measures	All three held fail-closed by their own /admin/data-privacy controls (coordinator_run_of_show, coordinator_day_of_broadcast, coordinator_requests_inbox); event-scoped RLS with canonical patterns only ; announcements are immutable and attributed — no silent edit or anonymous post; the run-of-show filter is a genuine minimisation (a vendor cannot read the parts of the day that are not theirs); no acknowledgment tracking was built, so reading an announcement is not recorded against a guest
Risk level	Low–Medium — the outward reach to guests is the notable part, and it is bounded to a short, attributed, event-scoped message. Public Privacy Policy §"Coordinators you invite (delegated access)" gained both missing paragraphs on 2026-08-02 (announcements + requests desk) — LIVE

DPS-20 · Couple→Supplier Payment Log — amounts the couple records against their own bookings (2026-08-17)

Field	Detail
Purpose	Let a couple keep their own record of what they have paid each supplier, against the payment milestones of a booking, and let the supplier confirm receipt. This is a LEDGER THE COUPLE WRITES — it is not a payment rail.
Why a separate entry	■ This activity was undeclared until 2026-08-17. The register relied on a platform-wide sentence that Setnayan " <i>never holds, moves, or records the transfer of any money</i> ", and used it as the reason the coordinator's money scopes needed no financial-data declaration. The "records" half was false , so the only financial records that exist in the product were undeclared on the strength of it.
Legal basis	Contract (§12(b)) — the budget/vendor-management service the couple engaged the platform for
Data subjects	Couples (organizers); suppliers (as payees); coordinators, where the couple has granted the money scope

Personal data categories	Amount in PHP, payment date, method (e.g. bank transfer, GCash), a free-text reference number, optional notes, an optional uploaded proof image, and the supplier + booking the payment is against. Plus who confirmed receipt and when
SPI?	N — financial information about a transaction the couple discloses themselves. No card numbers, no bank credentials and no account numbers are collected by the platform
Recipients / sub-processors	Supabase (Postgres, Singapore); Cloudflare R2 (Asia-Pacific) for an uploaded proof image. The supplier named on the row; a coordinator only where the couple granted the money scope
Cross-border transfer	SG (Supabase); APAC (R2, only where a proof image is uploaded)
Retention	Follows the parent event — life of the account (see DPS-01). ■ Financial records may attract the BIR/statutory floors of policy §4 where they evidence a taxable transaction; the couple↔supplier settlement is off-platform and is not Setnayan revenue , so the floor is not automatic. [TO CONFIRM WITH COUNSEL]
Security measures	RLS scoped to the event; the supplier sees only rows naming them; the coordinator's access is gated by the couple's opt-in money scope and the <code>coordinator_consent_money</code> control; proof images are signed-URL only
Risk level	Low–Medium — small volume, self-disclosed, no payment credentials. Measured in production 2026-08-17: 3 records totalling ■111,500 (2026-05-28 → 2026-06-05)
Note on the 0% commission position	Unchanged and still true: Setnayan never holds and never moves this money. The couple pays the supplier directly, off-platform. We record only what the couple tells us they paid

2. Threshold analysis — mandatory NPC registration

Under **RA 10173 and NPC Circular 17-01** (as amended), a PIC/PIP must register its DPS and DPO with the NPC when **any** of the following triggers is met. Assessment below.

#	Registration trigger (Circular 17-01 §4 / related issuances)	Setnayan assessment	Met?
1	Processing sensitive personal information of ≥ 1,000 individuals	Setnayan processes SPI: biometric face vectors (DPS-04), government ID + liveness for vendors (DPS-02), and potential health/religious data via RSVP dietary/special needs (DPS-03). Actual count [TO CONFIRM], but a weddings/events platform at scale is very likely to reach ≥1,000 SPI subjects	Likely YES

2	PIC/PIP with ≥ 250 employees	Sole proprietorship; headcount [TO CONFIRM] but almost certainly < 250	No (assumed)
3	Processing is likely to pose a risk to the rights and freedoms of data subjects	Yes — biometric processing, gov-ID + AML screening, guest likeness/media at scale, relationship graph, minors/legacy roadmap, and (DPS-12) involuntary identity-profiling with an automated decision that has a significant effect (auto-suspend/ban of a vendor's livelihood) . This is high-risk processing by nature	YES
4	Processing is not occasional (i.e., regular/systematic core-business processing)	Yes — data processing is the platform's core, continuous business function, not incidental	YES

Conclusion. Registration triggers **#1 (likely), #3, and #4 are met**. Trigger #2 is not (sole prop, sub-250 headcount). Under Circular 17-01 the criteria are **disjunctive** — meeting even one obligates registration, and Setnayan meets at least two independently (risk-to-rights + not-occasional), with the SPI-volume trigger also likely once counts are confirmed.

Recommendation: Setnayan should register its DPO and Data Processing Systems with the National Privacy Commission (NPC registration system), and appoint/confirm Indalecio Sacdalan Casasola II as the registered DPO. Registration is advisable on the risk-to-rights and not-occasional grounds alone; the SPI-volume trigger reinforces it. Confirm exact SPI data-subject counts [TO CONFIRM] and current NPC registration number [TO CONFIRM] before filing to determine whether this is an initial registration or an amendment.

3. Open items for DPO/counsel before filing

- [TO CONFIRM] Registered business address; headcount; SPI + total data-subject counts; existing NPC registration number.
- [TO CONFIRM] Exact RSVP special-data fields (dietary/health/religious) — determines whether DPS-03 is a formal SPI system.
- [TO CONFIRM] Jurisdictions/retention for Resend, PostHog (analytics), Vercel edge, Suno, and the face-matching engine host.
- [TO CONFIRM] Whether Maya Business (V1.5 payment gateway) is contracted; keep DPS-08 marked "not active" until then.
- DPS-06 (Person Graph) and the Person Graph amendment publish **only after** DPO/counsel sign-off; minors/legacy (Phase 3) require their own DPIA + NPC consultation before any build-to-live.
- DPS-13 (Vendor AI) and DPS-14 (Coordinator Delegated Access) are each held **fail-closed** by the in-app /admin/data-privacy control board; confirm the DPO ruling + finalize the Deep Search retention rule (180-day) before activating the corresponding controls. [TO CONFIRM]

Draft compliance artifact prepared to a compliant baseline ahead of counsel. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel; this document is not a substitute for legal review and is not yet adopted for NPC filing.